

Day 10: STTP on Ethical Hacking & Cyber Forensics @IIITK

Cyber Threat Intelligence & Quiz

Dr. Vinod P.

June 20, 2025

Contents

1	Cyber Threat Intelligence (CTI) Mining & Sharing	3
1.1	Indicators of Compromise (IoCs)	3
1.2	The Diamond Model of Intrusion Analysis	4
1.3	Organization-Specific Threat Intelligence (OSTIS)	4
1.3.1	Data Collection (Corpus Generation)	5
1.3.2	CTI Relevant Data Identification & Annotation	5
1.3.3	CTI Data Domain Tagging	6
1.3.4	Named Entity Recognition (NER) for CTI	6
1.3.5	Relation Extraction in CTI	8
1.3.6	Organization Specific Threat Intelligence Knowledge Graph (OSTIKG)	9
1.4	Secure CTI Sharing (SeCTIS Framework)	9
1.4.1	Federated Learning (FL)	9
1.4.2	SeCTIS Framework Details	10
1.5	Security Copilot (IntellBot - LLM Chatbot for CTI)	10
1.5.1	Knowledge Base Creation for IntellBot	10
1.5.2	Evaluation of IntellBot	12
1.6	Resources for Implementation (GitHub)	13
2	MCQ Quiz: Answers and Explanations	14
2.1	Question 1	14
2.2	Question 2	14
2.3	Question 3	14
2.4	Question 4	14
2.5	Question 5	14
2.6	Question 6	14
2.7	Question 7	15
2.8	Question 8	15
2.9	Question 9	15
2.10	Question 10	15
2.11	Question 11	15
2.12	Question 12	15
2.13	Question 13	15
2.14	Question 14	15
2.15	Question 15	16
2.16	Question 16	16
2.17	Question 17	16
2.18	Question 18	16
2.19	Question 19	16

2.20	Question 20	16
2.21	Question 21	16
2.22	Question 22	17
2.23	Question 23	17
2.24	Question 24	17
2.25	Question 25	17
2.26	Question 26	17
2.27	Question 27	17
2.28	Question 28	17
2.29	Question 29	18
2.30	Question 30	18

1 Cyber Threat Intelligence (CTI) Mining & Sharing

Cyber Threat Intelligence (CTI) is the collection, analysis, and interpretation of information about potential cyber threats to provide actionable insights. Its goal is to help organizations prevent or mitigate cyber-attacks by understanding adversary TTPs (Tactics, Techniques, and Procedures). CTI improves incident response, enables informed decisions, and safeguards assets.

The CTI lifecycle is an iterative process: Planning, Collection, Processing, Analysis, Dissemination, and Feedback. These phases often involve significant human expertise and decision-making:

- **Planning:** The team brainstorms and evaluates the infrastructure to safeguard. This involves defining objectives and intelligence requirements.
- **Collection:** Human analysts work to understand techniques used by hackers, collect data from various sources (detailed below), and create structured documentation.
- **Processing:** Documents and data, which may not follow a consistent structure (especially if publicly available), are post-processed by analysts. This can involve data cleaning and transformation.
- **Analysis:** Human experts identify patterns of attack and attribute them.
- **Dissemination & Feedback:** Analysts compile intelligence into reports, bulletins, etc., which are then shared with stakeholders. Feedback from stakeholders is crucial for refining future CTI efforts.

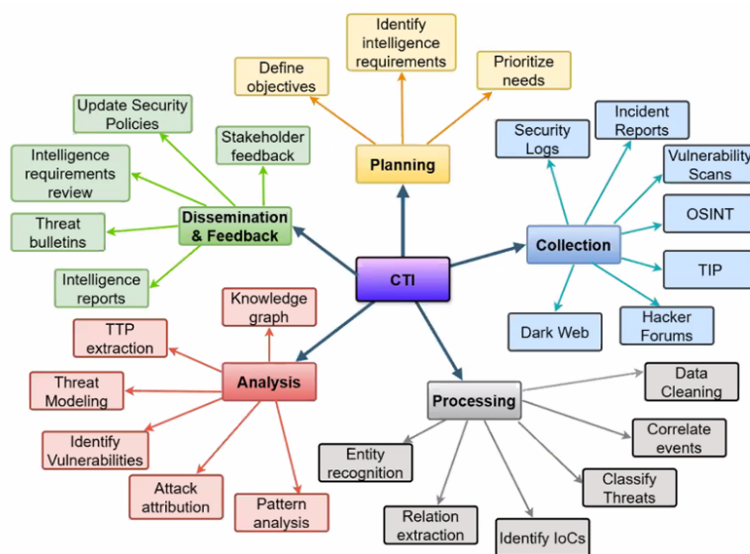


Figure 1: The Cyber Threat Intelligence Lifecycle

1.1 Indicators of Compromise (IoCs)

IoCs are forensic artifacts signaling a potential compromise. Types include network indicators (IPs, domains), cryptographic hashes of malware, vulnerability identifiers (CVEs), and observed attacker TTPs. While useful, IoCs often describe past events and can have a short lifespan as attackers change infrastructure.

- **Network** - domain names, URLs, IP/MAC/TOR addresses
- **Social** - User handles for Facebook/Twitter/Telegram/Github
- **Blockchain** - Addresses corresponding to Bitcoin/Ethereum/Litecoin/Monero/Dogecoin, etc
- **Cryptographic hash** - MD5/SHA1/SHA256/SHA512/ssdeep
- **Attack** - MITRE ATT&CK Tactics, Techniques and Procedures
- **Vulnerability** - CVE identifiers
- Location/Organization/Registry Keys

Figure 2: Examples of Indicator Types

1.2 The Diamond Model of Intrusion Analysis

This model describes cyber attacks using four interconnected components:

- **Adversary:** The threat actor.
- **Capability:** Tools and techniques used.
- **Infrastructure:** Systems used by the adversary.
- **Victim:** The target.

Understanding relationships between these (e.g., Adversary *uses* Infrastructure to deploy *Capability* against a *Victim*) helps analyze threats. Human analysts often map intelligence to this model.

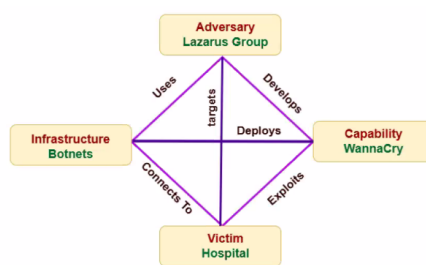


Figure 3: The Diamond Model

1.3 Organization-Specific Threat Intelligence (OSTIS)

OSTIS aims to tailor CTI to an organization's specific domain and threat landscape.

1.3.1 Data Collection (Corpus Generation)

A dataset of security-related text is built, primarily via web scraping from security blogs and news sites.

- **Process:** Use tools like Python’s ‘Requests’, ‘BeautifulSoup’, ‘Scrapy’, or ‘Selenium’ (for dynamic sites) to fetch and parse web content.
- **Human-Defined Criteria for Data Crawling:**
 - **Crawlability:** Examine ‘robots.txt’ for allowed access and restrictions.
 - **Publishing Frequency:** Evaluate blog post frequency, excluding those with infrequent posts (e.g., 2-3 posts in two months).
 - **Website Reputation:** Assess reputation through references in state-of-the-art studies and social media presence (e.g., include sources with more than 5,000 followers on platforms like Twitter, LinkedIn). Exclude sources not cited in recent CTI research.
- **Data Sources & Volume:** The corpus was generated by scraping a total of **39,166 blog posts** from various cybersecurity websites. Key sources included Alienvault, Bleeping Computer, CISCO (Talos Intelligence), CSO Online, Hacker News, Info Security Magazine, Kaspersky, KrebsOnSecurity, Malwarebytes, McAfee, Naked Security (Sophos), SANS Internet Storm Centre, Security Affairs, SUCURI, Symantec (Broadcom), Unit42 (Palo Alto Networks), SecureList, SOC Radar, Trellix, and Trend Micro.



Figure 4: Architecture for Web Crawling

1.3.2 CTI Relevant Data Identification & Annotation

Machine Learning (ML) classifies collected articles as CTI-relevant or not. This phase heavily relies on human input.

- **Human Annotation Process:**
 - **Team Composition:** A dedicated team of six master’s students and one Ph.D. scholar with cybersecurity expertise undertook the annotation.
 - **Task:** Annotators labeled articles as either CTI data (1) or non-relevant (0). Each annotator received a uniform set of 300 articles.

- **Methodology:** Annotators examined both titles and contents to assign appropriate labels. Training was provided using a 'studio' application for labeling.
- **Consensus & Quality Control:** Weekly consensus/disagreement meetings were held. Two faculty members cross-verified samples and made corrections. Disagreements were discussed to ensure annotator clarity. The process was completed in three weeks.
- **ML Method:** Train binary classifiers (e.g., using BERT variants like CySecBERT, RoBERTa) on this manually annotated data. Keywords and category tags are also utilized to extract relevant data, though web crawlers may initially retrieve non-relevant (noisy) content.
- **Annotation Quality Assessment:** Assessed using Fleiss' Kappa for inter-rater reliability. A final Kappa score of **0.913** was achieved, indicating almost perfect agreement among annotators.
- **Resulting Dataset Statistics:** The process generated a corpus with 6,341 non-relevant articles and 3,671 CTI relevant articles.

Classifier	Title			Content		
	P(%)	R(%)	F1-score	P(%)	R(%)	F1-score
CNN + Glove	82.29	82.03	0.820	78.15	77.63	0.775
BiLSTM + Glove	82.64	82.56	0.826	80.25	79.69	0.796
CNN with BiLSTM	82.51	82.35	0.823	80.55	80.30	0.803
CySec BERT	84.24	83.96	0.84	82.27	81.79	0.819
BERT Base	82.11	83.33	0.834	82.11	81.93	0.820
RoBERTa Base	84.27	84.04	0.841	82.42	82.1	0.822
Sec BERT	83.21	82.8	0.829	81.04	80.6	0.807
SciBERT	83.38	83.26	0.833	82.39	82.34	0.823

Figure 5: Performance of CTI Relevant Data Identification Models

1.3.3 CTI Data Domain Tagging

Relevant CTI articles are tagged with industry-specific domains (e.g., Government, Healthcare, Finance) using ML multi-class/multi-label classifiers (often BERT-based).

- **Explainability:** SHAP (SHapley Additive exPlanations) can identify which words contribute most to a domain prediction, enhancing model transparency for human analysts.

1.3.4 Named Entity Recognition (NER) for CTI

NER identifies and classifies key elements (entities) like threat actors, malware names, IP addresses, and vulnerabilities from CTI text.

Classifier	Title			Content		
	P(%)	R(%)	F1-score	P(%)	R(%)	F1-score
SecBERT	87.51	87.33	0.873	91.28	91.13	0.911
RoBERTa Base	90.93	90.69	0.907	92.14	92.03	0.920
BERT Base	90.19	90.04	0.900	92.17	92.09	0.921
CySecBERT	91.53	91.29	0.913	92.45	92.34	0.923
SciBERT	90.30	90.00	0.900	92.63	92.58	0.925

Figure 6: Performance of CTI Domain Tagging Models

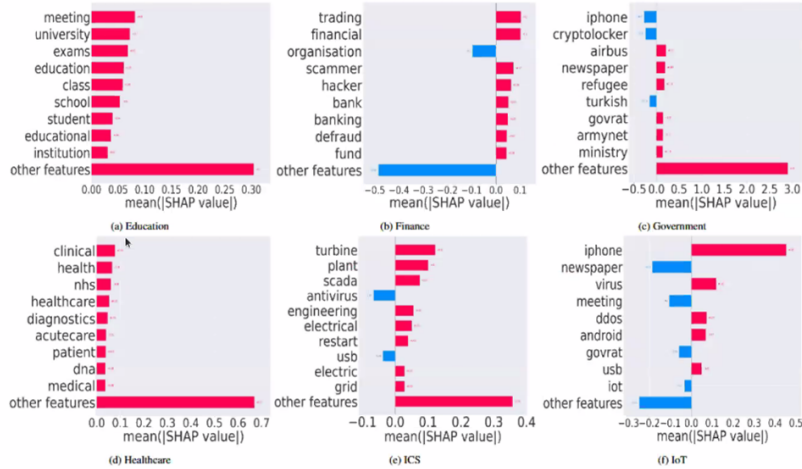


Figure 7: SHAP Explanations for Domain Classification

- **Human Annotation for NER:** Human annotation is crucial here as well, using the BIO (Beginning, Inside, Outside) tagging mechanism to label entities in the text. Standard NER models often require fine-tuning for domain-specific cybersecurity terms because terms like "virus" or "tool" have different meanings in cybersecurity versus other contexts.
- **Method:** Often uses a BERT+BiLSTM+CRF architecture.
- **Key Cyber Entities (align with STIX 2.1):** Attack Type, Campaign, Location, Malware, Threat Actor, Tool, Infrastructure, Asset, Vulnerability, Indicator, Identity, Date-Time. (12 Entities in total).

- **Annotation Evaluation for NER:** Fleiss’ Kappa was used for multi-annotator agreement, achieving a Kappa value of **0.75**, indicating substantial agreement.

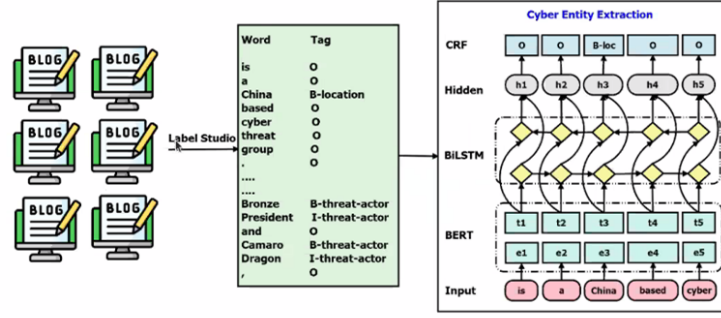


Figure 8: Architecture for NER-based Threat Information Extraction

Models	Precision	Recall	F-measure
BiLSTM	0.9609	0.9615	0.9608
BiLSTM-CRF	0.9602	0.9623	0.9609
BERT	0.9617	0.9612	0.9614
BERT-CRF	0.9624	0.9610	0.9616
BERT-BiLSTM-CRF	0.9645	0.9628	0.9635

Figure 9: Performance Comparison of Different NER Models (BERT-BiLSTM-CRF secured F1-Score of 0.9635)

1.3.5 Relation Extraction in CTI

This step identifies relationships between entities recognized by NER (e.g., ” *ThreatActor X uses Malware Y* ”).

- **Method:** A pipelined approach where NER is followed by a relation classification model (often BERT-based) on entity pairs. Human analysts define the types of relations to be

extracted.

- **Labels:** 14 relation labels were defined using the STIX framework (e.g., ‘activated-on’, ‘associated-with’, ‘attributed-to’, ‘belongs-to’, ‘compromises’, ‘controls’, ‘hosts’, ‘located-at’, ‘operated-on’, ‘originates-from’, ‘similar-to’, ‘targets’, ‘uses’, ‘variant-of’).
- **Performance:** BERT model achieved an F1-score of 0.887.

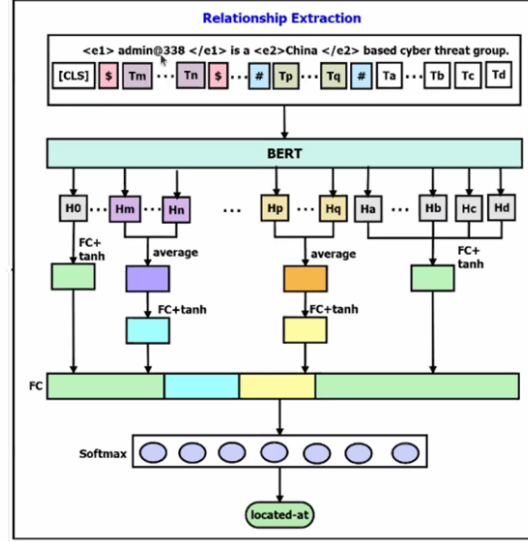


Figure 10: Relation Extraction Pipeline Approach

1.3.6 Organization Specific Threat Intelligence Knowledge Graph (OSTIKG)

Extracted entities and relations are structured into a knowledge graph (nodes = entities, edges = relations). This allows for visualization, complex querying, and discovery of hidden connections, often guided by human intelligence requirements.

1.4 Secure CTI Sharing (SeCTIS Framework)

Addresses challenges of sharing sensitive CTI by using privacy-preserving techniques. **Human Challenges in CTI Sharing:** Organizations are often reluctant to share CTI. Logs may contain Personally Identifiable Information (PII) or sensitive operational details. Fear of reputational damage or misuse of shared data by other organizations (e.g., for defamation) are significant concerns. Unknown data sources can also harm credibility, and establishing trusting relationships among entities is difficult.

1.4.1 Federated Learning (FL)

FL trains a global ML model collaboratively across multiple organizations without them sharing their raw data. Only model updates (parameters/gradients) are sent to a server for aggregation. **Process:** Initialize global model → Distribute → Clients train locally → Clients send updates → Server aggregates → Repeat.



Figure 11: Example of an Organization Specific Threat Intelligence Knowledge Graph

1.4.2 SeCTIS Framework Details

Integrates FL with Blockchain, Smart Contracts, Validators, and a Trust/Reputation model.

- **Blockchain:** For transparent and immutable storage of model information, validation scores, and reputation. Smart contracts automate processes.
- **Validators:** Trusted entities that assess local model quality using private data and compare it with the public model. Results influence the global model.
- **Trust/Reputation Model:** Scores participants based on the quality of their contributions, helping to mitigate malicious (Byzantine) clients or those submitting poor quality data. If a participant's reputation is damaged, the organization can be removed from being a validator.
- **Attack Model Considerations:** Human adversaries can attempt to alter data during collection (e.g., from compromised IoT sensors) or during labeling (e.g., label flipping/data poisoning to degrade model performance).

Evaluation showed SeCTIS effectively reduces misclassification rates even with Byzantine clients.

1.5 Security Copilot (IntellBot - LLM Chatbot for CTI)

An LLM-based chatbot providing real-time CTI assistance using Retrieval Augmented Generation (RAG). It aims to offer structured, contextual insights. **RAG Process:**

1. User query is received.
2. Relevant information is retrieved from a specialized CTI knowledge base.
3. Retrieved context and query are fed to an LLM.
4. LLM generates a grounded, context-aware answer.

1.5.1 Knowledge Base Creation for IntellBot

1. **Document Loading:** Ingest various CTI sources.
2. **Text Splitting:** Break documents into smaller chunks.
3. **Text Embedding:** Convert chunks into numerical vectors using models like Sentence-BERT.
4. **Vector Store:** Store embeddings in a system like FAISS for efficient similarity search.

Data Sources and Statistics for IntellBot Knowledge Base (Total: 332,476 items):

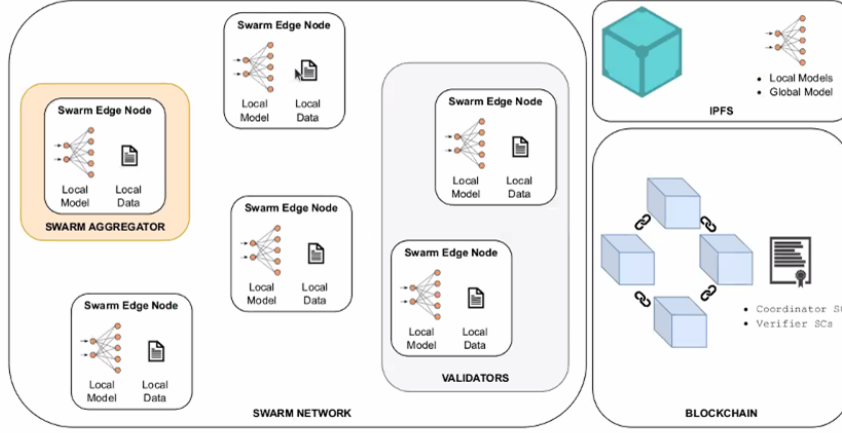


Figure 12: The General SeCTIS Architecture for Secure CTI Sharing

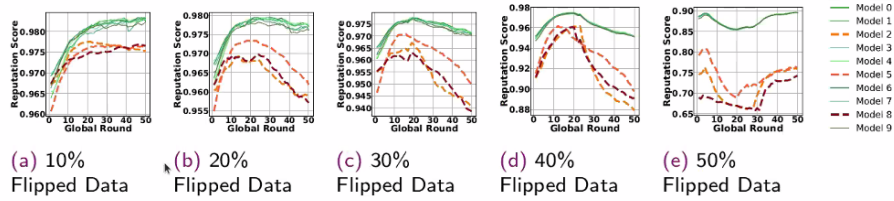


Figure 13: Reputation Score Analysis of Kronodroid (Byzantine clients Model 2, 5, 8 show lower reputation)

- **APT reports:** From vx-underground (Count: 2,002)
- **Book PDFs:** Cyber Security Books (Count: 445)
- **JSON Files:** From VirusTotal Website (Count: 7,989)
- **URLs:** From KrebsOnSecurity, Malwarebytes (Count: 2,959)
- **CSV Data:** From NVD and Blog Data (Count: 319,081)

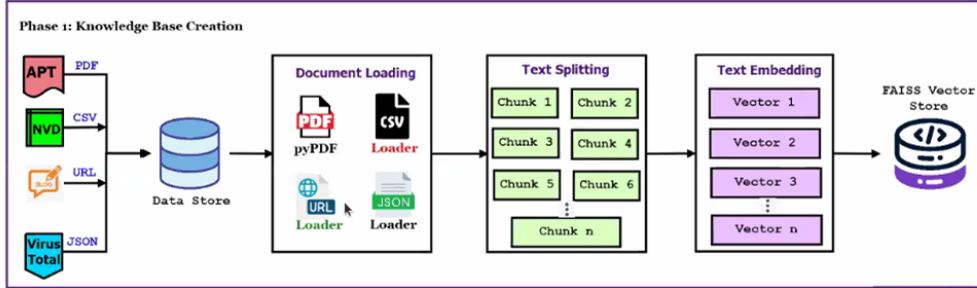


Figure 14: Knowledge Base Creation for the Security Copilot

1.5.2 Evaluation of IntellBot

Evaluated using BERT Score (comparing bot-generated questions to initial query), Cosine Similarity (bot vs. human responses), and RAG-specific metrics (Context Precision/Recall, Answer Faithfulness/Relevancy). This evaluation often involves human judgment to establish ground truth or assess the quality of generated responses.

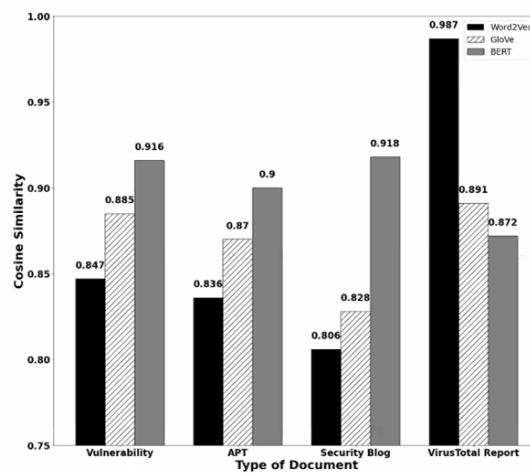


Figure 15: Average Cosine Similarity Scores for Bot vs. Human Responses

Type	Retrieval		Generation	
	CP	CR	F	AR
Vulnerability	0.934	0.933	0.908	0.855
APT Report	0.881	0.847	0.878	0.922
Security Blogs	0.805	0.889	0.871	0.883
VirusTotal Report	0.786	0.805	0.766	0.798

Figure 16: Retrieval and Generation Metric Scores for IntellBot

1.6 Resources for Implementation (GitHub)

The ‘OPTIMA-CTI’ GitHub organization hosts relevant projects:

- **SeCTIS:** <https://github.com/OPTIMA-CTI/SeCTIS> (Secure CTI Sharing)
- **Twitter-CTI:** <https://github.com/OPTIMA-CTI/Twitter-CTI> (CTI from Twitter)
- **DroidTTP:** <https://github.com/OPTIMA-CTI/DroidTTP> (Android Malware TTPs)
- **IntellBot:** <https://github.com/OPTIMA-CTI/IntellBot> (RAG Chatbot for CTI)

These repositories provide code and details for further learning and experimentation.

2 MCQ Quiz: Answers and Explanations

This section provides the selected answers and brief explanations for the quiz questions.

2.1 Question 1

Q: You enter ‘`<script>alert(“test”)</script>`’ into a blog’s comment section. When you reload the page, the alert box pops up. Vulnerability type?

A: Stored Cross-Site Scripting

Brief Explanation: The malicious script is stored on the server (in the comment) and executed when any user (including yourself on reload) views the page.

2.2 Question 2

Q: Best description of Suricata?

A: An intrusion detection and prevention system

Brief Explanation: Suricata is a well-known open-source NIDS/IPS and Network Security Monitoring engine.

2.3 Question 3

Q: Which is NOT related to malware distribution?

A: Tempting the user to watch the actions on the website

Brief Explanation: While a social engineering tactic, it’s not a direct malware distribution method itself, unlike phishing, drive-by downloads, or malvertising which actively deliver or lead to malware.

2.4 Question 4

Q: Tool to obtain Java source code from a mobile APK?

A: JADX

Brief Explanation: JADX is a decompiler that converts Android’s DEX files (Dalvik bytecode) into readable Java source code.

2.5 Question 5

Q: Capturing and reusing a session token from a different browser to access an account indicates what vulnerability?

A: Weak Session Management

Brief Explanation: Successful reuse of a session token across different contexts without proper validation (like IP binding, expiration) points to flaws in how sessions are managed and protected.

2.6 Question 6

Q: Tool to reverse engineer and modify an APK?

A: APKtool

Brief Explanation: APKtool decodes APKs into Smali code and resources, allowing modification and recompilation.

2.7 Question 7

Q: Entering 'admin' – ' as username (blank password) logs you in as admin. Most likely reason?

A: SQL Injection in login logic

Brief Explanation: The input 'admin' – ' likely comments out the password check in the backend SQL query, authenticating based only on the username 'admin'.

2.8 Question 8

Q: Required to decrypt TLS traffic in Wireshark if ECDHE is used?

A: Pre-Master-Secret log file from the client

Brief Explanation: ECDHE provides Perfect Forward Secrecy. Decryption requires the session-specific (Pre)-Master Secret, which browsers can log to a file. The server's long-term private key is not sufficient.

2.9 Question 9

Q: Wireshark filter `tcp.port == 443 && tls.handshake.type == 1` captures?

A: TLS Client Hello messages over HTTPS

Brief Explanation: 'tcp.port == 443' filters for HTTPS traffic, and 'tls.handshake.type == 1' specifically identifies the ClientHello message in a TLS handshake.

2.10 Question 10

Q: Wireshark filter for only HTTP traffic?

A: http

Brief Explanation: 'http' is the direct display filter in Wireshark for the HTTP protocol.

2.11 Question 11

Q: Choose the FALSE statement.

A: The investigators are supposed to perform analysis over data on the original device only once they take the forensic image/copy.

Brief Explanation: This is false. Forensic best practice is to always analyze a forensic copy (image) of the evidence to preserve the original.

2.12 Question 12

Q: Volatility plugin to list running processes during memory capture?

A: Pslist

Brief Explanation: 'pslist' is a standard Volatility plugin for listing processes by traversing the EPROCESS list in a memory dump.

2.13 Question 13

Q: What does Autopsy's "Hash Lookup" module help identify?

A: Known good or bad files based on hash comparison

Brief Explanation: This module compares file hashes against databases of known good (NSRL) or known bad (malware) file hashes.

2.14 Question 14

Q: Metasploit component that delivers code to the target system after exploitation?

A: Payload

Brief Explanation: The payload is the actual code (e.g., shell, meterpreter) that runs on the compromised target after an exploit succeeds.

2.15 Question 15

Q: Nmap port 443 shows "open—filtered" with no version detection. Inference?

A: Nmap cannot determine if the port is open because responses are being dropped or filtered

Brief Explanation: "open—filtered" means Nmap didn't receive a definitive response to classify the port as open or closed/filtered, often due to a firewall.

2.16 Question 16

Q: Nmap option for version detection of running services?

A: -sV

Brief Explanation: '-sV' is the Nmap switch that specifically enables service and version detection probes on open ports.

2.17 Question 17

Q: Purpose of Error Level Analysis (ELA) in multimedia forensics?

A: To visualize compression inconsistencies that may indicate tampering

Brief Explanation: ELA highlights differences in JPEG compression levels within an image, which can indicate areas that have been altered or added from different sources.

2.18 Question 18

Q: Uploading and executing a .php file with embedded code on a server represents what major risk?

A: Remote Code Execution

Brief Explanation: If an attacker can upload and execute server-side code (like PHP), they can run arbitrary commands on the server, which is RCE.

2.19 Question 19

Q: What does PRNU (Photo Response Non-Uniformity) help identify in image forensics?

A: Source device

Brief Explanation: PRNU is a unique noise pattern inherent to each digital camera sensor, acting like a fingerprint to identify the specific camera that took a photo.

2.20 Question 20

Q: Highest value finding for an attacker planning a targeted phishing campaign?

A: Email addresses and job roles scraped from LinkedIn

Brief Explanation: For targeted (spear) phishing, knowing email addresses and job roles allows attackers to craft highly convincing, personalized messages, increasing success rates.

2.21 Question 21

Q: Common tool for dynamic malware analysis?

A: OllyDbg

Brief Explanation: OllyDbg is a popular user-mode debugger for Windows, widely used to observe and analyze malware behavior while it's running.

2.22 Question 22

Q: Which step is NOT part of the forensic investigation process?

A: Prevention

Brief Explanation: While forensic findings inform prevention, prevention itself is a proactive security measure, not a reactive step within the investigation (which includes Identification, Preservation, Collection, Analysis, Reporting).

2.23 Question 23

Q: What can be analyzed using image metadata?

A: Device model and capture time

Brief Explanation: Image metadata (like EXIF) commonly stores camera make/model, date/-time of capture, GPS, and camera settings.

2.24 Question 24

Q: What does a 'packer' do in the context of malware?

A: Compresses and encrypts malware to avoid detection

Brief Explanation: Packers modify executables (compressing/encrypting) to obfuscate malware code, hindering static analysis and signature-based detection.

2.25 Question 25

Q: Inserting "" in a search bar causes unexpected behavior. Testing with " OR 1=1-" returns all products. Vulnerability?

A: SQL Injection in the WHERE clause

Brief Explanation: The " OR 1=1-" payload is a classic SQL injection that manipulates the WHERE clause of a SQL query to make the condition always true, bypassing filters.

2.26 Question 26

Q: Type of issue NOT detected by static code analysis tools?

A: Imports and processes

Brief Explanation: Static analysis examines code without execution. While it can analyze 'import' statements and code logic ("processes" within the code), it cannot fully analyze runtime behavior of OS processes, inter-process communication, or dynamic memory issues that only manifest at runtime. Other options (memory leaks patterns, many security vulnerabilities, coding style) are often detectable by SAST.

2.27 Question 27

Q: John the Ripper doesn't recognize a custom application's password hash format. Most appropriate first step?

A: Use john -list=formats and test sample hashes with -format=

Brief Explanation: First, check supported formats ('-list=formats'). Then, if the custom hash seems similar to a known one or you have a candidate format, test it with '-format={format_name};' on a sample.

2.28 Question 28

Q: Nmap -sV shows 3 hosts as "filtered." Switching to -Pn and scanning a known open port (e.g., 22) still gets no response. Probable reason?

A: Host-based firewalls on those systems drop all inbound probes

Brief Explanation: "Filtered" by -sV indicates blocking. -Pn assumes hosts are up. If a known open port scanned with -Pn also doesn't respond, it strongly suggests host-based firewalls are dropping packets to that port, even if the host is live.

2.29 Question 29

Q: Primary purpose of using Autopsy in digital forensics?

A: Analyzing digital evidence from storage media

Brief Explanation: Autopsy is a digital forensics platform for analyzing disk images and mobile device data, allowing examination of file systems, deleted files, registry, etc.

2.30 Question 30

Q: In Suricata, what is the purpose of the eve.json file?

A: To log real-time alerts and events

Brief Explanation: 'eve.json' is Suricata's primary output for structured logging of all event types (alerts, HTTP, DNS, TLS, flow data, etc.) in JSON format, suitable for an SIEM.